UT 2
Seguridad lógica

Seguridad Informática orientada a la programación

Curso: DAMSV_2A · 2026-2027

Profesor: Miguel Ángel García Cejudo

Formato: documento vertical resumido, manteniendo todos los apartados esenciales

Este documento reorganiza las 129 páginas originales en formato de estudio. Se acorta la redacción, pero se conservan los conceptos, ejemplos, actividades y preguntas de autoevaluación.

Objetivos y mapa de la unidad

- Reconocer las cinco fases habituales de un ataque y relacionarlas con medidas de seguridad lógica.
- Definir políticas de contraseñas, almacenamiento y copias de seguridad.
- Distinguir autenticación de autorización; comprender ACL, autenticación centralizada, SSO y protocolos AAA.
- Comparar tipos de backup, su restauración y su aplicación en una empresa.

Contenido

1. Introducción y seguridad lógica
2. Política de contraseñas y autenticación
3. ACL y permisos
4. Autenticación centralizada, SSO y protocolos
5. Almacenamiento, RAID, iSCSI, NAS y nube
6. Copias de seguridad y restauración
7. Caso práctico, actividades y autoevaluación

1. Introducción

1.1. Fases de un ataque

Un sistema debe instalarse, configurarse y actualizarse correctamente para reducir vulnerabilidades. Según el esquema CEH, un ataque suele avanzar en cinco fases:

1. Reconocimiento

El atacante reúne información del objetivo mediante fuentes públicas, ingeniería social o incluso dumpster diving. Puede ser pasivo, sin interacción directa, o activo, explorando red, routers y puertos.

2. Escaneo

Con la información previa se localizan equipos activos, puertos, servicios, sistema operativo y vulnerabilidades. Se usan comandos como traceroute y escáneres automatizados. El administrador debe cerrar todos los fallos; al atacante le basta uno.

3. Obtención de acceso

Se explota una vulnerabilidad o una mala configuración para entrar. También puede causarse daño sin acceso, por ejemplo mediante denegación de servicio. Influyen la arquitectura, la configuración y la destreza del atacante.

4. Mantenimiento del acceso

Tras entrar, el atacante intenta conservar el control mediante backdoors, troyanos o rootkits. Puede robar o alterar datos, consumir recursos o usar el equipo para atacar otros sistemas.

5. Borrado de huellas

Se eliminan o alteran registros y atributos de archivos para ocultar la intrusión, mantener el acceso y dificultar una investigación. Esta fase suele comenzar mientras se consolida la persistencia.

1.2. Medidas de seguridad

La protección efectiva combina varias capas. Ninguna medida aislada elimina el riesgo.

- Política de contraseñas: longitud, complejidad, caducidad, historial e intentos permitidos.
- ACL: acceso a archivos, carpetas, aplicaciones y dispositivos solo para usuarios o grupos autorizados.
- Criptografía: confidencialidad, integridad, autenticidad y no repudio.
- Política de almacenamiento: rendimiento, disponibilidad, accesibilidad y reducción de paradas.
- Copias de seguridad: periodicidad, alcance, destino, cifrado y restauración.
- Protección antimalware: desde spam hasta ransomware como CryptoLocker.
- Hardening y actualización continua del software.
- Seguridad perimetral mediante cortafuegos, proxies y VLAN.
- Alta disponibilidad con servidores redundantes y virtualización.

La criptografía sirve de base a muchas de estas medidas y se estudia con mayor profundidad en otras unidades.

2. Política de contraseñas y autenticación

2.1. Conceptos básicos

Autenticar es confirmar que una persona, proceso, servicio o dispositivo es quien afirma ser. La autorización ocurre después y determina qué acciones puede realizar el usuario autenticado.

- El resultado de la autenticación es acceso autorizado o rechazo. El rechazo puede deberse a credenciales incorrectas o a una cuenta bloqueada o deshabilitada.
- Login inicia una sesión y logout la finaliza.
- Las contraseñas son personales e intransferibles; cada persona debe usar una cuenta propia.
- Nunca se deben conservar credenciales predeterminadas ni usar una cuenta administradora para el trabajo cotidiano.

Principio de mínimo privilegio

Un administrador debería tener una cuenta limitada para el uso diario y otra privilegiada para tareas de administración. Así, una vulnerabilidad explotada en una aplicación obtiene menos capacidad de daño y el atacante aún tendría que elevar privilegios.

2.2. Administración en Linux y Windows

En Linux, root es el superusuario. El comando su inicia una sesión como root; sudo ejecuta acciones concretas con privilegios elevados para usuarios autorizados en sudoers. Sudo evita introducir la contraseña de root, aunque concentra el riesgo en la cuenta del usuario autorizado. Windows suele solicitar credenciales de administrador cuando una tarea lo requiere.

- No todos los usuarios deben poder ejecutar sudo.
- Las operaciones elevadas deben quedar limitadas y auditadas.
- La separación entre cuenta normal y cuenta administrativa reduce el impacto de malware y exploits.

2.3. Elementos de una política de contraseñas

La política debe responder de forma explícita a estas decisiones:

- Longitud mínima y complejidad: minúsculas, mayúsculas, números y símbolos.
- Caducidad y número de contraseñas anteriores que no pueden reutilizarse.
- Número de intentos fallidos antes del bloqueo y duración de este.
- Equipos o ubicaciones autorizadas para iniciar sesión, identificados por IP, MAC o nombre cuando proceda.
- Protección de BIOS/UEFI y del gestor de arranque.

> Los sistemas domésticos suelen imponer menos restricciones que los sistemas empresariales, donde el administrador configura políticas más estrictas y diferenciadas.

2.4. Verificación en dos pasos y FIDO

La autenticación de doble factor combina algo que el usuario sabe, como una contraseña, con algo que posee o es, como un teléfono, una llave o un rasgo biométrico.

- El segundo factor puede ser un código temporal, una notificación o un enlace de aprobación.
- Es habitual en banca, sistemas operativos, redes sociales y CMS como WordPress o Drupal.
- Google Authenticator, Microsoft Authenticator y Authy son ejemplos de aplicaciones de códigos.
- U2F y FIDO2 permiten usar llaves de seguridad. Yubico fabrica YubiKeys compatibles con servicios web, Linux mediante PAM y Windows Hello.

3. Listas de control de acceso (ACL)

3.1. Usuarios, grupos y autorización

Tras autenticar al usuario, el sistema aplica permisos. La organización recomendada consiste en asignar usuarios a grupos que representan roles, como ventas, contabilidad o dirección, y conceder permisos a los grupos.

- Un usuario puede pertenecer a varios grupos.
- Sistemas como Windows incluyen grupos predefinidos: usuarios autenticados, usuarios del dominio y administradores.
- Buena práctica: conceder permisos a grupos, no directamente a usuarios, incluso si el grupo solo tiene un miembro.

3.2. Tipos de permisos

Los permisos dependen del recurso y del sistema de archivos. En NTFS se distinguen permisos básicos y avanzados.

- Lectura: entrar o ejecutar, listar o leer, consultar atributos y permisos.
- Escritura: crear archivos o carpetas, escribir o anexar datos, cambiar atributos y eliminar.
- Administración: tomar posesión, cambiar permisos y tener control total.

3.3. Funcionamiento de una ACL

Una ACL almacena, como metadatos del recurso, los usuarios y grupos a los que se concede o deniega cada permiso.

- En Linux, el modelo clásico usa rwx para propietario, grupo y otros.
- Las ACL avanzadas se consultan y modifican con getfacl y setfacl cuando el sistema de archivos está configurado para ello.
- SELinux y AppArmor añaden controles empresariales más avanzados.
- Predominio de la denegación: una denegación explícita prevalece sobre una concesión. Si no existe permiso aplicable, el acceso también se rechaza.
- Herencia: archivos y subcarpetas reciben los permisos de la carpeta superior, aunque puede romperse o ampliarse la herencia.
- El administrador puede tomar posesión o administrar permisos.
- Las ACL también protegen impresoras, sockets, dispositivos y otros recursos. En Linux muchos aparecen como archivos virtuales en /dev.

4. Autenticación centralizada

4.1. Necesidad y ventajas

Replicar cuentas en todos los equipos provoca errores, trabajo duplicado y dificultad para auditar. La centralización mantiene una base de datos común de usuarios y grupos que todos los equipos consultan.

4.2. Windows: Active Directory

Active Directory almacena usuarios, equipos, grupos y otra información en controladores de dominio. Es recomendable disponer de varios controladores con replicación para mantener el servicio.

- Usuarios y equipos de Active Directory gestiona los objetos del dominio.
- Las GPO aplican configuraciones centralizadas.
- Desde Windows Server 2012, el Centro Administrativo de Active Directory permite políticas de contraseña detalladas para distintos usuarios o grupos.

4.3. Linux: PAM y LDAP

PAM es un sistema modular de autenticación. La biblioteca pam_unix.so usa /etc/passwd y /etc/shadow; otras bibliotecas permiten biometría o consulta de bases remotas.

- LDAP es una base jerárquica optimizada para búsquedas frecuentes y modificaciones poco habituales.
- Puede centralizar usuarios y grupos en Linux.
- Active Directory amplía conceptos de LDAP e incorpora la administración mediante GPO.

4.4. Single Sign-On (SSO)

SSO permite introducir las credenciales una sola vez y acceder a varias aplicaciones. Un servidor de identidades autentica y entrega un token que las aplicaciones confían y suelen guardar como cookie.

- Flujo: acceso a la aplicación, consulta al servidor de identidades, redirección si no existe sesión, autenticación, emisión del token y acceso.
- Las aplicaciones deben estar diseñadas para delegar la autenticación.
- OpenID es un protocolo de identidad; Auth0 es una plataforma/API relacionada con identidad y acceso.

4.5. Protocolos de autenticación y AAA

Los protocolos de autenticación transportan o verifican credenciales. Los protocolos AAA añaden autorización y contabilidad del consumo de recursos.

- EAP transporta distintos métodos, como EAP-MD5 o EAP-MSCHAPv2. PEAP protege EAP dentro de un túnel TLS.
- Kerberos interviene mediante AS, TGS y el servicio final. AS y TGS suelen formar el KDC. Primero se obtiene un TGT, después un ticket de servicio y finalmente se accede al recurso. Es una forma de SSO y requiere relojes sincronizados mediante NTP.
- RADIUS es AAA, suele consultar una base de usuarios y usa UDP, normalmente el puerto 1812. Se emplea en accesos de red y registra tiempo, ancho de banda u otros consumos.
- TACACS+ es una alternativa asociada a Cisco que opera sobre TCP.

5. Política de almacenamiento

5.1. Criterios

La política decide qué datos se guardan, dónde y con qué tecnología, considerando cantidad, importancia, rendimiento y coste.

- Ubicación: local, remota, distribuida o nube; la centralización facilita las copias.
- Tipo: HDD, SSD o soportes de backup según rendimiento, capacidad y presupuesto.
- Redundancia: RAID para tolerar determinadas averías físicas.
- Alta disponibilidad: replicación en varias ubicaciones y acceso transparente aunque falle un componente.

5.2. RAID

Un RAID agrupa discos y se presenta como una unidad. Puede implementarse por hardware mediante controladora o por software mediante el sistema operativo. Si un disco falla, el conjunto puede quedar degradado y debe reconstruirse cuanto antes con una unidad nueva.

- RAID no sustituye al backup: no protege de borrados, corrupción, malware, errores lógicos o desastres.
- JBOD y LVM combinan capacidad, pero no equivalen por sí mismos a redundancia.
- La reconstrucción consume tiempo y aumenta el riesgo mientras el conjunto está degradado.

Nivel	Mínimo	Características
RAID 0	2	Distribuye bloques y mejora rendimiento/capacidad, pero no aporta redundancia.
RAID 1	2	Espejo. Lecturas rápidas y alta tolerancia, pero la capacidad útil equivale a una sola unidad.
RAID 5	3	Paridad distribuida. Tolera un fallo; un segundo fallo causa pérdida. Escrituras más lentas.
RAID 10	4	Espejos agrupados con striping. Buen rendimiento y redundancia; no deben fallar dos discos del mismo espejo.
RAID 50	6	Varios RAID 5 agrupados. Tolera como máximo un fallo por grupo RAID 5.

5.3. Hot spare y elección

Un hot spare es un disco instalado y preparado para sustituir automáticamente a otro que falle. La elección del RAID debe equilibrar seguridad, capacidad, rendimiento y coste.

- Con tres discos, RAID 1 prioriza tolerancia y rendimiento; RAID 5 aprovecha más capacidad pero solo tolera un fallo.
- Con cuatro discos, RAID 10 ofrece gran rendimiento para cargas como bases de datos, pero sigue necesitando backups frecuentes.
- También se requieren SAI, monitorización y copias de seguridad.

6. Disponibilidad y almacenamiento remoto

6.1. Protocolos de acceso

El almacenamiento remoto permite compartir datos sin copiarlos en cada equipo y concentrar redundancia y disponibilidad.

- Acceso por archivos: NFS, SMB, FTP, WebDAV y AFP.
- Acceso por bloques: iSCSI, que presenta una unidad remota como si fuera un disco local.

6.2. iSCSI y SAN

iSCSI permite particionar y formatear desde el cliente una unidad remota. Es frecuente en virtualización y en redes SAN de alta velocidad.

- LUN: unidad lógica que el servidor ofrece.
- Target: identificador IQN y reglas de acceso asociadas al LUN; puede usar CHAP.
- Initiator: componente cliente que envía comandos SCSI por TCP/IP.
- Varios equipos no deben escribir sobre el mismo LUN sin un sistema de archivos preparado para clúster, pues podrían corromper los datos.
- En Windows se inicia el servicio del iniciador iSCSI y se configura el Target para montarlo tras el arranque.
- Un LUN puede alojarse en RAID y facilita reemplazar rápidamente un servidor que falle.

6.3. NAS en alta disponibilidad

Dos NAS empresariales pueden formar un clúster activo-pasivo. Uno atiende la red y el otro toma el control si falla el primero. Una conexión heartbeat independiente permite detectar el estado de los nodos.

6.4. Nube

La nube distribuye y replica datos entre centros del proveedor. Ofrece elasticidad y disponibilidad, pero amplía la superficie de exposición y exige un análisis de riesgos, ubicación, acceso, cifrado, continuidad y dependencia del proveedor.

- Servicios domésticos: Dropbox, OneDrive, Google Drive e iCloud, normalmente con sincronización y versionado.
- Servicios profesionales: Amazon S3, Azure Storage, Oracle Cloud, IBM Cloud/SoftLayer y soluciones empresariales de Google.
- La selección debe considerar protección de datos, residencia, contrato, solvencia, exportación y recuperación.

Nota de actualización: el material original incluye referencias legales y nombres de productos de distintas fechas. Para una aplicación real deben verificarse las versiones vigentes y el RGPD/LOPDGDD actual.

7. Política de copias de seguridad

7.1. Finalidad

RAID no evita la necesidad de respaldos. Las copias sirven para recuperar datos tras fallos físicos, ransomware, borrados, corrupción, migraciones o necesidad de consultar estados anteriores.

- El origen son los datos seleccionados; el destino es donde se guarda el backup.
- La copia puede comprimirse y cifrarse, con un coste adicional de CPU y tiempo.
- Debe permitir restauración total o selectiva, según el software.

7.2. Tipos de copia

Los tres tipos principales se diferencian por qué cambios guardan y qué piezas hacen falta para restaurar.

Tipo	Qué guarda	Restauración y uso
Completa	Todo el origen.	Restauración simple, pero ocupa más y tarda más. Adecuada como base o copia externa.
Diferencial	Cambios desde la última completa.	Necesita la completa y la última diferencial. Crece cada día.
Incremental	Cambios desde la copia anterior.	Optimiza tiempo y espacio; puede requerir toda la cadena. Facilita versionado.

Instantáneas

Una snapshot es una imagen consistente de bloques creada casi al instante. No sustituye al backup, pero permite copiar en segundo plano sin detener el servicio. Se usa en virtualización y en tecnologías como Volume Shadow Copy de NTFS. Los puntos de restauración protegen componentes del sistema, no necesariamente datos personales.

7.3. Elementos de la política

Toda política debe documentar:

- Origen de los datos y prioridad.
- Frecuencia, horario y ventanas de copia.
- Destino local, externo, remoto o nube.
- Tipo, compresión, cifrado, retención y versionado.
- Responsables de custodia, claves y registros.
- Pruebas periódicas de restauración.

En empresas son comunes copias diarias o incluso incrementales cada hora. La estrategia forma parte de BCDR: continuidad de negocio y recuperación ante desastres.

7.4. Aplicaciones y restauración

Los equipos personales pueden usar Historial de archivos, herramientas específicas como Cobian Backup o software del fabricante. En servidores se emplean soluciones especializadas, utilidades del hipervisor, herramientas del NAS, Acronis Backup o Microsoft Data Protection Manager.

- Las copias modernas pueden trabajar por bloques modificados, lo que evita copiar bases de datos o buzones completos cada vez.
- La restauración se usa ante borrado, corrupción, fallos de actualización, avería de disco o consulta de versiones antiguas.
- Una restauración puede sobrescribir la versión actual; para comparar versiones conviene renombrar el archivo actual o usar una herramienta de comparación.
- Una copia que nunca se ha probado no ofrece una garantía real de recuperación.

8. Caso práctico: política de backup en una pyme

8.1. Infraestructura

El ejemplo plantea una pyme con los siguientes componentes:

- Servidor Dell con Intel Xeon, 32 GB de RAM y tres HDD de 500 GB en RAID 5; ejecuta Proxmox con VM de Active Directory, web y base de datos.
- NAS Synology de seis bahías: RAID 1 de datos con dos HDD de 4 TB, un HDD de 4 TB como hot spare, RAID 1 de backup con dos HDD de 6 TB y una bahía libre.
- Dos HDD eSATA externos de 6 TB usados de forma alterna.
- Cuenta Amazon S3 de 50 TB para recuperación ante grandes desastres.
- Fibra simétrica de 600 Mbps y 30 PC Windows unidos a Active Directory.

8.2. Plan de copias

La política combina varias capas y automatiza casi todo:

- 01:00 cada día: snapshot de las VM de Proxmox al NAS, sin detenerlas.
- 03:00 cada día: copia por sectores y con versiones de los datos del NAS, retenidas hasta seis meses.
- Cada semana: copia completa, comprimida y cifrada a uno de dos discos externos alternos, custodiado fuera de la sede. El desfase máximo de esa capa es de siete días.
- Cada dos semanas a las 23:00: incremental a Amazon S3; se eliminan copias de más de 60 días.
- El administrador y personas designadas de dirección conocen las claves de cifrado y acceso.
- Proxmox y Synology envían informes por correo; el administrador revisa resultados y atiende fallos.

El diseño tiene un nivel de protección alto y cierta redundancia entre copias. Su valor está en combinar recuperación rápida, copia externa física y copia geográficamente separada.

9. Actividades propuestas

2.1 - Usuarios domésticos

Explicar por qué cada miembro de una familia necesita su propia cuenta y por qué no deben usarse contraseñas vacías.

2.2 - sudo

Comparar inconvenientes de sudo con la solicitud de credenciales de una cuenta administradora real.

2.3 - Comparación de 2FA

Estudiar Google Authenticator y compararlo con Microsoft Authenticator y Authy.

2.4 - RAID por software

Crear un RAID en Linux con mdadm y repetirlo en Windows con Espacios de almacenamiento.

2.5 - DPAT

Usar Domain Password Audit Tool en un dominio de pruebas o autorizado para analizar la fortaleza de contraseñas.

2.6 - Métodos de acceso de Google

Configurar inicio con teléfono y verificación en dos pasos; comparar seguridad, ventajas e inconvenientes.

2.7 - NAS y RAID 1

Instalar FreeNAS/TrueNAS, OpenMediaVault o XigmaNAS con tres discos; crear RAID 1, simular fallo y observar reconstrucción.

2.8 - Hot spare

Añadir el tercer disco como repuesto y comprobar la sustitución automática, respetando si el hardware admite extracción en caliente.

2.9 - iSCSI

Crear LUN y Target en el NAS, conectarlo desde Windows y verificar que aparece como disco local.

2.10 - Cobian Backup

Crear trabajos de copia y probar restauración de archivos individuales.

2.11 - Sistemas de archivos

Investigar qué sistemas Linux admiten snapshots.

2.12 - Historial de archivos

Configurar Windows para copiar Documentos a una unidad USB.

2.13 - Recuperación física

Investigar empresas de recuperación de discos, valorar el coste de recuperar datos vitales y métodos de borrado seguro.

10. Autoevaluación

1. Según CEH, ¿cuántas fases tiene un ataque? a) Cinco. b) Cuatro. c) Tres.

2. El método persistente instalado tras acceder es: a) Vulnerability scanner. b) Backdoor. c) Dumpster diving.

3. Tras autenticarse: a) puede rechazarse; b) puede autorizarse; c) ambas son posibles.

4. En una ACL, los permisos: a) solo grupos; b) solo usuarios; c) grupos y usuarios, recomendándose grupos.

5. SSO requiere un servidor central de confianza llamado: a) token; b) SSO Server; c) servidor de identidades.

6. AAA significa: a) Authentication, Assimilation and Assembling; b) Administration, Actualisation and Authorization; c) Authentication, Authorization and Accounting.

7. RAID 5 tolera sin pérdida: a) un disco; b) todos menos uno; c) varios si no es el de paridad.

8. La unidad ofrecida por un servidor iSCSI se llama: a) LUN; b) Target; c) Initiator.

9. Según el planteamiento legal del material, los servidores con datos personales no deben ubicarse: a) fuera de España; b) fuera de la UE; c) en cualquier lugar con contrato.

10. El tipo relacionado con file versioning es: a) completa; b) diferencial; c) incremental.

Soluciones

1.a · 2.b · 3.c · 4.c · 5.c · 6.c · 7.a · 8.a · 9.b según el material original · 10.c

Fin del resumen. Para estudio práctico, conviene acompañar estos conceptos con laboratorios controlados de permisos, RAID, iSCSI, autenticación y restauración.